NEXATECH SOLUTIONS

Information Security & Data Protection Policy

Document Reference: ISP-2024-v3.2

Effective Date: January 1, 2025

Review Cycle: Annual | Owner: Chief Information Security Officer

Classification: CONFIDENTIAL

1. Company Overview

NexaTech Solutions Inc. is a cloud-based SaaS provider headquartered in Austin, Texas, with regional offices in London (UK), Singapore, and Toronto (Canada). Founded in 2014, NexaTech delivers enterprise workflow automation and analytics platforms to over 1,200 customers across 34 countries, primarily in the financial services, healthcare, and manufacturing sectors.

NexaTech employs approximately 620 full-time employees globally and engages with approximately 150 contractors and third-party service providers at any given time. Annual recurring revenue (ARR) exceeds $95 million as of the 2024 fiscal year.

Certifications	ISO 27001:2022 · SOC 2 Type II · PCI DSS Level 1 · HIPAA Business Associate · GDPR Article 28 Processor

2. Data Classification & Handling

NexaTech classifies all data into four tiers based on sensitivity and regulatory obligation. All employees and contractors must adhere to handling requirements corresponding to the data's classification level.

2.1 Classification Tiers

Classification	Definition	Examples
Tier 1 — Public	Information approved for external release	Marketing content, press releases, public API docs
Tier 2 — Internal	General business information for internal use	Internal wikis, project plans, non-sensitive emails

Tier 3 — Confidential	Sensitive business or personal data requiring protection	Customer PII, financial records, contracts, source code
Tier 4 — Restricted	Highly sensitive data with strict access controls	Encryption keys, health records, payment card data, credentials

2.2 Data Retention

Retention periods are defined by data type and applicable regulation:

- Customer transaction records: 7 years (financial regulation compliance)
- Employee HR records: Duration of employment plus 5 years
- Security logs and audit trails: 12 months online; 7 years archived
- Incident response records: 5 years from incident close
- Marketing and analytics data: 3 years or until consent withdrawal
- Backup snapshots: 30-day rolling window; quarterly backups retained for 1 year

3. Access Control Policy

NexaTech implements a Zero Trust access model. No system, user, or device is inherently trusted. All access requests are authenticated, authorized, and continuously validated.

3.1 Authentication Requirements

- Multi-Factor Authentication (MFA) is mandatory for all employees, contractors, and privileged accounts. Acceptable second factors: TOTP authenticator app or FIDO2 hardware token. SMS OTP is not permitted for Tier 3/4 data systems.
- Passwords must be at least 14 characters, contain uppercase, lowercase, numbers, and symbols, and must not appear in the HaveIBeenPwned breach database.
- Password rotation is required every 90 days for privileged accounts; 180 days for standard accounts.
- Single Sign-On (SSO) via SAML 2.0 is used for all SaaS applications. Standalone credentials for SSO-enabled apps are prohibited.
- Session timeout: 30 minutes of inactivity for admin consoles; 8 hours for standard web applications.

3.2 Role-Based Access Control (RBAC)

Access to systems is granted on the principle of least privilege. Every role is defined with explicit permissions; no implicit access is granted.

Role	Access Level	Review Frequency
Standard Employee	Tier 1–2 data; own work systems only	Annual
Team Lead / Manager	Team data; project-specific Tier 3 access	Semi-annual

Engineer (Production)	Production read access; no direct data access	Quarterly
DevOps / SRE	Infrastructure access via PAM; no persistent privileges	Monthly
CISO / Security Team	Full audit access; Tier 4 with dual-approval	Monthly
Contractors	Scoped to engagement; no Tier 4 access	Per-engagement

3.3 Privileged Access Management (PAM)

All privileged access (root, admin, service accounts) is managed through CyberArk PAM. Privileged sessions are recorded and retained for 12 months. Just-in-time (JIT) access is required for production environments — permanent privileged accounts are prohibited. Privileged account credentials rotate automatically every 24 hours.

4. Encryption Standards

4.1 Data at Rest

- All Tier 3 and Tier 4 data stored on NexaTech infrastructure is encrypted using AES-256-GCM.
- Database encryption is enforced at the storage layer using AWS KMS customer-managed keys (CMKs). Key rotation occurs automatically every 365 days.
- Laptop and endpoint full-disk encryption is enforced via BitLocker (Windows) and FileVault 2 (macOS). Compliance is monitored via MDM (Jamf/Intune).
- Backup archives are encrypted with a separate key hierarchy; backup encryption keys are escrowed with a hardware security module (HSM).

4.2 Data in Transit

- All data transmitted over public networks uses TLS 1.2 minimum; TLS 1.3 is preferred and enforced for customer-facing APIs.
- TLS 1.0 and 1.1 are globally disabled across all NexaTech infrastructure and customer endpoints.
- Internal service-to-service communication within the production VPC uses mutual TLS (mTLS) with certificate lifetimes of 90 days maximum.
- Email containing Tier 3/4 data must use S/MIME or PGP encryption. Plaintext email of sensitive data is prohibited.

4.3 Key Management

Encryption key management follows NIST SP 800-57 guidelines. Master keys are stored in HSMs. Key custodians are designated per business unit. No single individual has access to both encrypted data and its encryption key.

5. Incident Response

5.1 Severity Classification

Severity	Criteria	Response SLA
SEV-1 Critical	Active breach, ransomware, or data exfiltration confirmed	15 minutes to engage CISO; 1-hour customer notification
SEV-2 High	Suspected breach, significant service disruption, or Tier 4 data exposure	1 hour to security team; 4-hour stakeholder notification
SEV-3 Medium	Policy violation, minor data exposure, or failed attack attempt	4 hours to acknowledge; 24-hour remediation plan
SEV-4 Low	Security tool alert, misconfiguration detected, or phishing report	24-hour review; 72-hour resolution target

5.2 Incident Response Team

- Incident Commander: CISO or designated deputy
- Security Analyst team: 24/7 on-call rotation via PagerDuty
- Legal/Compliance: Engaged for SEV-1 and SEV-2 incidents
- Communications Lead: Responsible for customer and regulator notifications
- External Forensics Retainer: CrowdStrike (IR retainer maintained annually)

5.3 Breach Notification

NexaTech complies with all applicable breach notification laws. Under GDPR Article 33, regulators are notified within 72 hours of confirmed breach discovery. Affected data subjects are notified within 30 days unless law enforcement requests a delay. US state breach notification laws (including CCPA) are followed with the most stringent applicable timeline applied globally.

6. Vendor & Third-Party Risk Management

All third-party vendors with access to NexaTech systems or customer data must undergo security assessment prior to onboarding. The vendor risk program is managed by the Procurement and Security teams jointly.

6.1 Vendor Assessment Tiers

Vendor Tier	Access Type	Assessment Required
Critical (Tier A)	Production data access or infrastructure hosting	Full security questionnaire + on-site audit
High (Tier B)	Development or staging environment access	Security questionnaire + evidence review

Medium (Tier C)	Internal tooling access only	Abbreviated questionnaire + SOC 2 review
Low (Tier D)	No system access (e.g., office supplies)	Standard procurement process only

6.2 Sub-Processor List (Key)

NexaTech maintains a full sub-processor register. Key infrastructure sub-processors include:

- Amazon Web Services (AWS): Primary cloud hosting — US-East-1, EU-West-1, AP-Southeast-1
- Snowflake: Data warehousing (enterprise analytics tier only)
- Twilio SendGrid: Transactional email delivery
- Stripe: Payment processing (PCI DSS scope)
- Auth0 (Okta): Customer identity and access management
- Datadog: Infrastructure monitoring and log aggregation
- CrowdStrike Falcon: Endpoint detection and response (EDR)

7. Business Continuity & Disaster Recovery

7.1 Recovery Objectives

RTO	Recovery Time Objective: 4 hours for Tier 1 services; 24 hours for Tier 2 services
RPO	Recovery Point Objective: 1 hour for production databases; 24 hours for secondary systems

7.2 Infrastructure Resilience

- Production services run across 3 AWS Availability Zones within each region (active-active configuration).
- Cross-region replication is enabled for all Tier 3/4 data: primary region US-East-1 replicates to US-West-2 with a 15-minute lag SLA.
- Database failover is automated via AWS RDS Multi-AZ; failover time target is under 60 seconds.
- CDN and DDoS protection provided by AWS CloudFront and AWS Shield Advanced (always-on).
- Annual DR test is mandatory; results and any gaps reported to the Board Audit Committee.

7.3 Backup Policy

Daily automated backups are performed for all production databases. Backups are stored in a separate AWS account to prevent ransomware impact. Restoration is tested quarterly; restoration results are logged and reviewed by the Security team.

8. Regulatory Compliance

8.1 Applicable Frameworks

- ISO/IEC 27001:2022 — Certified; certificate number IS-79234, valid through October 2026
- SOC 2 Type II — Annual audit; most recent report covers April 2024 – March 2025 (Trust Services Criteria: Security, Availability, Confidentiality)
- PCI DSS v4.0 Level 1 — Qualified Security Assessor (QSA) assessed; Attestation of Compliance (AOC) available under NDA
- HIPAA — Business Associate Agreements (BAA) executed with all healthcare customers; minimum-necessary access enforced
- GDPR — Data Processing Agreements (DPA) in place; Data Protection Officer: Sarah Mitchell (dpo@nexatech.io)
- CCPA/CPRA — Privacy notices updated; data subject rights request process operational (30-day SLA)

8.2 Audit & Assessment Schedule

Assessment Type	Frequency	Last Completed
Internal security audit	Quarterly	Q3 2024
External penetration test	Annual + after major releases	September 2024
SOC 2 Type II audit	Annual	March 2025
ISO 27001 surveillance audit	Annual	October 2024
Vulnerability scanning (ASV)	Weekly automated	Continuous
Red team exercise	Biennial	June 2024

9. Security Awareness & Training

All NexaTech employees and contractors complete mandatory security awareness training as a condition of employment and continued engagement.

- Onboarding: All new hires complete 4-hour security awareness training within their first 5 business days.
- Annual refresher: Mandatory annual training covering phishing, social engineering, data handling, and acceptable use. Completion rate target: 100%; non-compliance escalated to HR.

- Phishing simulations: Monthly simulated phishing campaigns. Employees who click are automatically enrolled in remedial training. Click-through rates are reported quarterly to leadership.
- Role-specific training: Engineers complete secure coding training (OWASP Top 10); DevOps complete cloud security training; Finance completes fraud awareness training — all annually.
- Security champions program: Volunteer network of 25+ employees across departments who act as security liaisons and receive advanced quarterly training.

10. Physical Security

NexaTech's primary offices employ layered physical security controls. Primary data processing occurs in AWS-managed data centres, which maintain SOC 1 Type II and ISO 27001 certifications independently.

- Office access: Badge-controlled entry for all office locations. Visitor log maintained; all visitors escorted.
- Secure zones: Server rooms and network equipment areas require dual-factor physical authentication (badge + PIN). Access limited to authorised IT staff.
- Clear desk policy: Employees must not leave Tier 3/4 information visible when away from their desk. Locking of workstations required when leaving workstation.
- CCTV: All office entry/exit points and server rooms are monitored 24/7. Footage retained for 90 days.
- Device disposal: All devices containing Tier 3/4 data are wiped to NIST 800-88 standard before disposal or repurposing. Certificates of destruction are obtained for physical media.

Document Control

Version	Date	Change Summary
v1.0	March 2020	Initial policy release
v2.0	January 2022	Added CCPA, updated PCI DSS section
v3.0	January 2024	ISO 27001:2022 alignment, Zero Trust model addition
v3.2	January 2025	Updated sub-processor list; added red team section; SOC 2 refresh

Approved by: Marcus Chen, CISO | Dr. Priya Nair, CEO | Board Audit Committee